Shahjalal University of Science and Technology
Department of Computer Science and Engineering
4th Year 1st Semester Final Examination Jan 2024 (Session: 2020-21)
Course Code: CSE 461 Credits: 3 Course Title: Introduction to Computer Security & Forensics
Time: 3 hrs Total Marks: 100

Group A
[Answer all the questions]

1. Answer any FIVE 5x2=10

a) Why is ensuring the CIA triad important in a vulnerable environment?
b) How many different passwords are possible of length 6 with only alphanumeric characters?
c) What dilemma will the attacker face when the ciphertext is less than the unicity distance?
d) Which access control mechanism is the most time-efficient for handling any access-related queries?
e) Mention two tools of integrity.
f) Find Z^*_n and $\phi(n)$ for $n = 14$.
g) Why isn't security by obscurity adopted by the companies?
h) How is the OFB mode capable of encrypting or decrypting all of the blocks parallelly?

2. Answer any FOUR 4x5=20

a) Why do we need asymmetric encryption even after having symmetric encryption?
b) SUST's website uses a privately designed encrypted channel for back-and-forth communication between the server and the clients. SUST invests a significant amount of its budget and takes sophisticated security measures throughout the year to ensure the high security of the whole website. Any user visiting the site can access the results of any student.
Which security principles are violated in the above mentioned scenario? Explain.
c) Consider two passwords:
(i) *Password A:* contains 10 letters chosen from both lowercase and uppercase letters (a-z & A-Z).
(ii) *Password B:* contains 4 letters chosen from lowercase and uppercase letters (a-z & A-Z), 3 numbers (0-9) and 2 special characters (e.g. @, #, $).
Which password is more secure (mathematically and practically) and why?
d) You want to send a 1GB video file securely to your friend. During transmission, some random blocks might be lost. But as it's a video, loss of some random frames shouldn't impact the overall view.
Which AES mode of operation will be more suitable for this operation? Explain.
e) Differentiate between public key cryptography and private key cryptography in terms of their working principles, key usage and security features.
f) Let's assume we represent a hexadecimal character using 4 bits. We consider the following S-box using a bigram table (split 4 bits into 2 bigrams) that is used for encryption and decryption.

	00	01	10	11
00	0011	0100	1111	0001
01	1010	0110	0101	1011
10	1110	1101	0100	0010
11	0111	0000	1001	1100

You're given a ciphertext as: **CB7F1**. Decrypt the text using the given table.

3. Answer any TWO 2x10=20

a) Let SUST has newly introduced the e-certificate using RSA signature. Here, SUST is the issuer, students are the holders, and other authorities verifying the students' documents are the verifiers of the e-certificate. This system needs a rigorous setup and design to work properly.
(i) Create the system design for the e-certificate system with these three entities and with proper setup. Also, verify that your design will work correctly.
(ii) Which attacks should SUST still consider to secure the system?
b) SUST plans to store student data (image, textual information, and large academic documents). IT teams decided to use AES-256 for encryption. Developers used AES in ECB mode for simplicity. For backup, encrypted copies are uploaded to the cloud server.
(i) What problems might arise from using ECB mode?
(ii) Could RSA be a better option for this scenario?
(iii) Some perpetrators have somehow compromised the key. What measures can be taken?
(iv) What risks exist in uploading the backups to the cloud server?

CamScanner

c) A bank is developing a secure banking system. For password storage, they proposed to use a hash function and MACs for the transactions. Developers didn't implement any salting as hash is used and didn't feel salting necessary.
(i) Why are both hashes and MACs necessary for the system? Explain according to the scenario.
(ii) Which risks might still occur for the unsalted hashed passwords? How could salting improve the security? Explain with complexity analysis.

Group B
[Answer all the questions]

4. Answer any FIVE **5x2=10**

a) How many different codes can be generated in a 1 inch x 1 inch QR code with 100 pixels per inch (PPI)?
b) What is a primitive root for any number?
c) Write down the cryptographic protocol for the situation, "S sends a document M to V after signing and V verifies it".
d) What is a ransomware?
e) What is meant by the 10-character access control notation **dr-xr- - - wx** ?
f) What should be your firewall setting if you want to prevent your network from being used for a SMURF DoS attack?
g) Explain rainbow table attack.
h) Define a brute force attack in cryptography. Then, explain the different strategies that can be applied to make a brute force attack more time-efficient.

5. Answer any FOUR **4x5=20**

a) Why do we need virtual memory? How is it managed by the OS to ensure faster execution?
b) Explain how an attacker can impose TCP session hijacking?
c) In Markle-Damgard construction for hashing, let n = m = 8 bits. Assuming and $v = d_0 = 0$ and $C = (M_l , d_{l-1}) = (d_{l-1} * 26 + (M_l - 'A' + 1)) \% 107$. Find the final hash value of the string "**THIEF**".
d) How does DNS name resolution work when you ask for the IP address of any domain name?
e) Explain how botnets can be used to initiate a DDoS attack.
f) Differentiate between trojans and worms.

6. Answer any TWO **2x10=20**

a) Let's assume, Alice wants to send a message **M = 43** to Bob encrypting using Elgamal cryptosystem. You picked a prime number **p = 113** and a primitive root in Z_p is **g = 34**. Next you picked a random number **x = 97** which is your secret key. Alice picked a random number **k = 37**.
(i) Can the Elgamal cryptosystem be used as a mean for key distribution? Explain with an example.
(ii) Find the encrypted pair of the message generated by Alice.
(iii) Write down the equation for the decryption step Bob took and provide its correctness.

b) SUST hosts an online portal for the students for registering courses, checking grades and paying different fees. Recently, the portal has been attacked. Now, if any student tries to visit the portal with proper url, it redirects to the attacker's IP address. The attacker has also implemented a fake but same portal in his IP and hence it can collect credentials and card information also. IT team is getting numerous reports of unauthorized charges and suspicious activities in the students' university accounts.
(i) Explain how this attack is imposed by the attacker?
(ii) Suggest security measures the IT team could have implemented to defend against this attack.

c) An e-commerce website implements HTTPS using a digital certificate to ensure secure online transactions between the server and the customers. The server presents its certificate during TLS handshaking. Still, some customers are falling victim to attacks by some malicious fake websites.
(i) How does a digital certificate protect against an attacker's fake website?
(ii) Why might some users still fall victim? Explain with example.
(iii) Suggest best practices that any e-commerce website should follow to ensure its certificate is always trusted by users' browsers and secure throughout the session?

CamScanner